

C1 fix — same-origin /api/v1 base URL + fresh bundle re-embed

Revision: 1 **Last modified:** 2026-07-10T21:55:00Z **Scope:** clients/ota-manager/src/lib/api-client.ts, .../src/hooks/use-auth.ts, new .../src/__tests__/api-client-baseurl.test.ts, re-embedded server/internal/api/manager-dist/. **Authority:** §11.4.4 (STOP-on-discovery), §11.4.6 (no-guess — confirmed against the real server routing), §11.4.115 (RED → GREEN), §11.4.142 (independent review — this fix closes the SR-stream C1 Critical), §11.4.108 (SOURCE → ARTIFACT: the source fix is only real once the shipped artifact carries it), §11.4.30 (build-artifact note).

1. The defect (two coupled, both CONFIRMED)

From the adversarial security review (docs/research/security_headers_adversarial_review_20260710/, C1):

1. **CSP break.** api-client.ts defaulted baseURL to the absolute http://localhost:8080 when VITE_API_BASE_URL was unset (and no build sets it). The literal was in the embedded bundle. The Tier-C SPA CSP connect-src 'self' (992bd497) blocks any off-origin API call → the Manager UI's API calls fail at **every deployment whose origin ≠ http://localhost:8080**.
2. **Latent 404 (found while fixing #1, §11.4.6).** The data endpoints were written bare (/deployments, /devices, /releases, ...) while the server registers **every** route under APIBasePath (server.go:129 v1 := r.Group("/api/v1"), no bare registrations). So with the absolute base, data calls hit http://localhost:8080/deployments → **404 on the real server**; only /api/v1/auth/* (fully-prefixed in the client) worked. The mocked vitest suite masked this entirely — it never hits the real routes.

2. The fix (root cause)

- `api-client.ts`: `baseUrl` default → **relative** `/api/v1` (same-origin → CSP `connect-src 'self' safe`; `VITE_API_BASE_URL` still overrides for split-origin dev).
- `use-auth.ts`: auth paths `/api/v1/auth/{login,refresh}` → `/auth/{login,refresh}` (relative to the base — no double prefix).
- Net: **every** request now resolves same-origin under `/api/v1`.

3. Proof (real captured evidence)

Check	Result
§11.4.115 guard <code>api-client-baseurl.test.ts</code> — GREEN on fix	8/8 PASS
§11.4.115 RED on the restored absolute <code>baseUrl</code> (captured)	8/8 FAIL (proves the test detects the defect)
Full ota-manager regression	vitest 44/44 (was 36; +8), tsc 0
Fresh <code>npm run build bundle</code>	<code>localhost:8080</code> in <code>dist/assets</code> : 0 files ; <code>/api/v1</code> : 1 file
Re-embed <code>server/internal/api/manager-dist/</code>	<code>localhost:8080</code> : 0 ; <code>/api/v1</code> : 1 ; <code>index.html</code> → <code>index-N6EDVn3e.js</code> + <code>index-BD87r2I_.css</code> (consistent)
Server embed compiles + CSP/ <code>embed/manager</code> tests	<code>go build ./...</code> OK; <code>go test -run 'SecurityHeaders SPACSP Embed Manager'</code> ok 6.5s

4. §11.4.108 SOURCE → ARTIFACT closure

The source fix alone does not fix the SHIPPED UI — the previously-embedded bundle still carried the absolute URL. This fix therefore ALSO rebuilds ota-manager and re-embeds the fresh same-origin bundle into `server/internal/api/manager-dist/` (the `go:embed` source), so the artifact the server actually serves is now CSP-compatible. Both layers verified.

5. Honest boundary (§11.4.6 / §11.4.30)

- `server/internal/api/manager-dist/` is TRACKED (required for `go:embed` at build time) despite `embed.go`'s comment calling it

gitignored — a pre-existing §11.4.30 contradiction. This fix updates the already-tracked bundle to the correct version; the proper resolution (gitignore + generate via a wired build pipeline, §11.4.173) remains a tracked follow-up (item K / build-pipeline), NOT worsened here.

- `clients/ota-manager/dist/` (also tracked, also a build artifact) is left unstaged — not needed to ship (the server embed is the shipped copy); same item-K cleanup.
- This closes C1's correctness. I1 (HSTS-behind-proxy, operator trusted-proxy config) and I2/I3 (server test seams) remain tracked per the SR dispositions.

Sources verified

Sources verified 2026-07-10: - `axios baseURL/getUri` URL composition — https://axios-http.com/docs/req_config - CSP `connect-src` — <https://developer.mozilla.org/docs/Web/HTTP/Headers/Content-Security-Policy/connect-src>